CÓDIGOCLARO · RUTA JAVASCRIPT

Tema 15 · Seguridad web

Guía de estudio · DAM/DAW

XSS, sanitización, CORS, cookies y validación.

1. Explicación

Trata como no confiables los datos de usuario y API. textContent muestra texto sin analizarlo como HTML; innerHTML puede abrir XSS. Valida también en servidor. CORS regula qué respuestas puede leer otro origen desde el navegador, pero no reemplaza autorización. Configura cookies según el flujo con Secure, HttpOnly y SameSite.

2. Ejemplo

Código · javascript

```
const salida = document.querySelector("#salida");
const dato = "<img src=x onerror=alert(1)>";
salida.textContent = dato;
console.log(salida.textContent);
```

Resultado esperado

```
El marcado se muestra como texto literal; no se interpreta como HTML.
```

3. Errores frecuentes

- Asignar entrada no confiable a innerHTML.
- Confiar solo en la validación del navegador.
- Creer que CORS autoriza al usuario a realizar acciones en el servidor.

4. Ejercicio

Muestra entrada como texto plano, rechaza un campo obligatorio vacío y valida de nuevo en el servidor.

Casos que debe superar

Entrada	Resultado esperado
"Hola"	se muestra como texto
marcado con script	se muestra literal
campo vacío obligatorio	se rechaza con mensaje accesible

5. Solución explicada

Código · javascript

```
const formulario = document.querySelector("#formulario");
const entrada = document.querySelector("#mensaje");
const salida = document.querySelector("#salida");
formulario.addEventListener("submit", (evento) => {
  evento.preventDefault();
  if (entrada.value.trim() === "") { entrada.setCustomValidity("Escribe un mensaje."); entrada.
reportValidity(); return; }
  entrada.setCustomValidity("");
  salida.textContent = entrada.value; // El servidor valida antes de guardar.
});
```

Otras soluciones válidas

- Sanitizar HTML con una biblioteca mantenida si se permite marcado limitado.
- Restringir CORS y aplicar autorización real en el servidor.

6. Fuentes oficiales

OWASP — Cross Site Scripting Prevention Cheat Sheet · MDN — Cross-Origin Resource Sharing (CORS)